كسر كلمات المرور: (Password Cracking)

هجمات القاموس(Dictionary Attacks) :

تجربة كل كلمة ثم المتغيرات الواضحة لها من قاموس كبير ومقارنتها مع قيمة الهاش الموجودة في ملف كلمات المرور.

هجمات جداول قوس قزح(Rainbow Table Attacks) :

إنشاء جداول مسبقة تحتوي على قيم الهاش لجميع قيم الـ salt الممكنة.

وهي جداول ضخمة جدًا من قيم الهاش.

على سبيل المثال: جدول بحجم ١,٤ جيجابايت يمكنه كسر ٩٩,٩% من كلمات مرور نظام ويندوز المكونة من أحرف وأرقام خلال ١٣,٨ ثانية.

لكن تصبح هذه الطريقة غير عملية عند استخدام قيم salt أكبر.

كسر كلمات المرور: (Password Cracking)

هو عملية محاولة اكتشاف او استرجاع كلمات المرور المخزنة او المستخدمة في الأنظمة، وذلك غالبًا من خلال تحليل قيم الهاش (Hash) أو باستخدام أساليب تخمين مختلفة.

تشمل طرق كسر كلمات المرور ما يلي:

- هجمات القاموس : (Dictionary Attacks) استخدام قائمة كلمات شائعة وتجربتها.
- هجمات القوة الغاشمة : (Brute Force Attacks) تجربة جميع الاحتمالات الممكنة حتى يتم العثور على كلمة المرور الصحيحة.
- هجمات جداول قوس قزح (Rainbow Table Attacks): استخدام جداول معدة مسبقًا من قيم الهاش لتسريع عملية الكسر.

الهدف من هذه العملية قد يكون:

- اختبار قوة أنظمة الحماية (في الاختبارات الأمنية).
- أو الوصول غير المصرح به إلى الأنظمة في الهجمات الإلكترونية).

Password choices

- قد يختار المستخدمون كلمات مرور قصيرة
- مثال: حوالي ٣ كانت مكونة من ٣ أحرف أو أقل، وبالتالي يسهل تخمينها
- يمكن للنظام رفض كلمات المرور القصيرة جدًا
- قد يختار المستخدمون كلمات مرور سهلة التخمين لذلك يستخدم المخترقون قوائم بكلمات مرور محتملة وشائعة
- مثال: أظهرت إحدى الدراسات على ١٤٠٠٠ كلمة مرور مشفرة أنه تم تخمين ما يقارب ربعها

- قد يستغرق الأمر حوالي ساعة واحدة على أسرع الأنظمة لحساب جميع الاحتمالات، ويكفي فقط كسر كلمة مرور واحدة لتحقيق الاختراق!

التحكم في الوصول إلى ملف كلمات المرور (Password File access control):

- مكن منع هجمات التخمين غير المتصل Offline Guessing Attacks)من خلال منع الوصول إلى كلمات المرور المشفرة
- يتم إتاحتها فقط للمستخدمين ذوي الصلاحيات (Privileged Users)
- غالبًا يتم ذلك باستخدام ملف منفصل لكلمات المرور يُعرف باسمShadow
- Password file
- ومع ذلك، لا تزال هناك بعض الثغرات :
- استغلال أخطاء في نظام التشغيل أو البرامج
- حدوث خطأ في الأذونات يجعل الملف قابلاً للقراءة
- استخدام نفس كلمة المرور في أنظمة أخرى
- الوصول إلى النسخ الاحتياطية غير المحمية
- التقاط كلمات المرور عبر الشبكة غير المؤمنة (Sniffing)

التحكم في الوصول إلى ملف كلمات المرورPassword File Access Control

هو مجموعة من السياسات والإجراءات التي تهدف إلى حماية ملف كلمات المرور (خصوصا الملفات التي تحتوي على قيم الهاش من الوصول غير المصرح به، وذلك لمنع هجمات كسر كلمات المرور.

أهم آليات التحكم:

- قصر الوصول إلى ملف كلمات المرور على المستخدمين ذوي الصلاحيات فقط (Premium users
- استخدام ملف منفصل مثل Shadow Password File لتخزين كلمات المرور المشفرة بعيدًا عن المستخدمين العاديين.
- . تطبيق صلاحيات وصول صارمة) (Permissions بحيث لا يمكن قراءة الملف إلا من قبل النظام أو المدير.
- تشفير كلمات المرور باستخدام خوارزميات قوية مع استخدام Salt لزيادة الأمان.

أهداف التحكم:

- منع هجمات التخمين غير المتصل) Offline Guessing Attacks
- حماية بيانات المستخدمين من التسريب.
- تقليل فرص استغلال الثغرات الأمنية.

التحديات والثغرات المحتملة

- أخطاء في إعداد الصلاحيات قد تجعل الملف متاحا للقراءة.
- استغلال ثغرات في نظام التشغيل أو التطبيقات.
- الوصول إلى النسخ الاحتياطية غير المؤمنة.
- إعادة استخدام كلمات المرور في أنظمة أخرى.
- التقاط كلمات المرور عبر الشبكات غير المشفرة.

استخدام كلمات مرور أفضلUsing Better Passwords

من الواضح وجود مشكلات في كلمات المرور

الهدف هو القضاء على كلمات المرور سهلة التخمين، مع الحفاظ على سهولة تذكرها من قبل المستخدم

التقنيات المستخدمة:

توعية المستخدمين (:(User Educationتدريب المستخدمين على اختيار كلمات مرور قوية وعدم إعادة استخدامها

كلمات مرور يتم إنشاؤها بواسطة الحاسوب (Computer-Generated Passwords:) إنشاء كلمات مرور عشوائية يصعب تخمينها

الفحص التفاعلي لكلمات المرور (:(Reactive Password Checking التحقق من كلمات المرور بعد استخدامها واكتشاف الضعيفة منها

الفحص الاستباقي لكلمات المرور (Proactive Password Checking منع اختيار كلمات المرور الضعيفة من البداية عن طريق سياسات قوية

تشير إلى اتباع ممارسات وأساليب تساعد في إنشاء كلمات مرور قوية يصعب تخمينها أو كسرها، مع الحفاظ على سهولة تذكرها للمستخدم.

أهم الإرشادات:

- استخدام كلمات مرور طويلة (يفضل ١٢ حرفًا أو أكثر)
- الجمع بين الأحرف الكبيرة والصغيرة والأرقام والرموز
- تجنب الكلمات الشائعة أو المعلومات الشخصية (مثل الاسم أو تاريخ الميلاد)
- عدم استخدام نفس كلمة المرور في أكثر من نظام
- تغيير كلمات المرور بشكل دوري عند الحاجة

أساليب فعّالة:

- استخدام عبارات مرور ((Passphrasesمثل جملة طويلة سهلة التذكر وصعبة التخمين
- الاعتماد على برامج إدارة كلمات المرور ((Password Managers لتوليد وتخزين كلمات مرور قوية

- تفعيل المصادقة الثنائية (Two-Factor Authentication - 2FA) لزيادة الأمان

الهدف:

تحقيق توازن بين الأمان وسهولة الاستخدام، بحيث تكون كلمة المرور قوية ضد الهجمات وسهلة التذكر للمستخدم.

الفحص الاستباقي لكلمات المرور (Proactive Password checking)

فرض القواعد مع تقديم إرشادات للمستخدم، مثل:

- أن تكون كلمة المرور ٨ أحرف أو أكثر
- تحتوي على أحرف كبيرة وصغيرة وأرقام وعلامات ترقيم

ومع ذلك، قد لا يكون ذلك كافيًا

- برامج كسر كلمات المرور ((Password Crackers

تعتمد على الوقت والذاكرة (Time and Space)لمحاولة كسر كلمات المرور

- نموذج ماركوفMarkov Model

يُستخدم لتوليد كلمات مرور محتملة يمكن تخمينها بناءً على أنماط شائعة وبالتالي يتم رفض أي كلمة مرور يمكن لهذا النموذج توليدها

- مرشح بلومBloom Filter

يُستخدم لبناء جدول يعتمد على قاموس من خلال قيم الهاش

ثم يتم فحص كلمة المرور المطلوبة بمقارنتها مع هذا الجدول لمعرفة ما إذا كانت ضعيفة أو شائعة

الفحص الاستباقي لكلمات المرور (Proactive Password Checking

هو عملية التحقق من قوة كلمة المرور أثناء إنشائها، وقبل قبولها من النظام، بهدف منع اختيار كلمات مرور ضعيفة أو سهلة التخمين.

آلية العمل:

- يقوم النظام بفحص كلمة المرور لحظة إدخالها من المستخدم
- يتم مقارنتها مع سياسات الأمان (مثل الطول والتعقيد)
- يتم رفضها إذا كانت ضعيفة أو شائعة

الأساليب المستخدمة:

- التحقق من طول كلمة المرور (مثلاً ٨ أحرف أو أكثر)
- التأكد من احتوائها على مزيج من الأحرف الكبيرة والصغيرة والأرقام والرموز
- مقارنة كلمة المرور مع قوائم كلمات المرور الشائعة (Dictionary)

- استخدام تقنيات مثل Bloom Filter لاكتشاف الكلمات الشائعة بسرعة
- استخدام نماذج مثل Markov Model للتنبؤ بالكلمات القابلة للتخمين ورفضها

المزايا:

- يمنع اختيار كلمات مرور ضعيفة من البداية
- يقلل من فرص نجاح هجمات كسر كلمات المرور .
- يعزز مستوى الأمان العام للنظام

العيوب:

- قد يسبب إزعاجًا للمستخدمين إذا كانت القواعد صارمة جدًا
- قد يدفع المستخدمين لكتابة كلمات المرور في أماكن غير آمنة لتذكرها

الهدف:

تحقيق توازن بين الأمان وسهولة الاستخدام من خلال فرض سياسات قوية دون تعقيد تجربة المستخدم.

شيء يمتلكه المستخدم للمصادقة Object User Possesses to Authenticate

هو نوع من عوامل التحقق في أنظمة الأمن يعتمد على ما يملكه المستخدم" لإثبات هويته.

يُستخدم ضمن أسلوب المصادقة الثنائية أو متعددة العوامل.

أمثلة:

- بطاقة بارزة) : (Embossed Cardبطاقة تحتوي على بيانات مطبوعة بارزة يمكن قراءتها أو التحقق منها
- بطاقة الشريط المغناطيسي (: (Magnetic Stripe Card بطاقة تحتوي على شريط مغناطيسي يخزن بيانات المستخدم
- بطاقة ذاكرة ((Memory Card بطاقة تخزن بيانات رقمية تستخدم للتحقق من الهوية
- البطاقة الذكية (:(Smart Card بطاقة تحتوي على شريحة إلكترونية قادرة على معالجة وتخزين البيانات بشكل آمن

الفكرة الأساسية:

لا يكفي معرفة كلمة المرور فقط، بل يجب امتلاك عنصر مادي (مثل بطاقة أو جهاز) لإثبات الهوية.

الهدف:

- تعزيز الأمان
- تقليل فرص الاختراق حتى لو تم سرقة كلمة المرور
- دعم أنظمة المصادقة متعددة العوامل ((Multi-Factor Authentication

Memory Card

تخزين البيانات دون معالجتها ((Store but do not process data

هي وسيلة مصادقة تعتمد على تخزين معلومات المستخدم فقط دون القدرة على معالجتها أو تنفيذ عمليات حسابية عليها داخل البطاقة.

أمثلة:

- بطاقة الشريط المغناطيسي (Magnetic Stripe Card مثل بطاقة البنك
- بطاقة الذاكرة الإلكترونية (Electronic Memory Card))

الاستخدام:

- يمكن استخدامها بمفردها للتحكم في الوصول المادي (Physical Access)
- أو استخدامها مع كلمة مرور/ رقم سري (PIN)للوصول إلى أنظمة الحاسوب

العيوب:

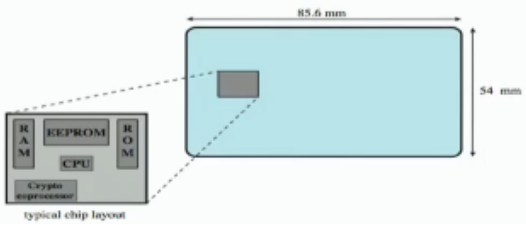
- الحاجة إلى قارئ خاص (Special Reader) لقراءة البيانات
- مشاكل عند فقدان البطاقة (Loss of Token))
- عدم رضا المستخدمين بسبب الحاجة لحمل بطاقة إضافية باستمرار

Smart card

تخزين البيانات دون معالجتها Store but do not process data

هي وسيلة مصادقة تعتمد على تخزين معلومات المستخدم فقط دون القدرة على معالجتها أو تنفيذ عمليات حسابية عليها داخل البطاقة.

أمثلة:



- بطاقة الشريط المغناطيسي (Magnetic Stripe Card مثل بطاقة البنك
- بطاقة الذاكرة الإلكترونية (Electronic Memory Card))

الاستخدام:

- يمكن استخدامها بمفردها للتحكم في الوصول المادي)(Physical Access)
- أو استخدامها مع كلمة مرور / رقم سري (PIN)للوصول إلى أنظمة الحاسوب

العيوب:

- الحاجة إلى قارئ خاص (Special Reader) لقراءة البيانات
- مشاكل عند فقدان البطاقة (Loss of Token))
- عدم رضا المستخدمين بسبب الحاجة لحمل بطاقة إضافية باستمرار

المصادقة بناءً على الخصائص الفيزيائية للمستخدم Authentication based on physical properties

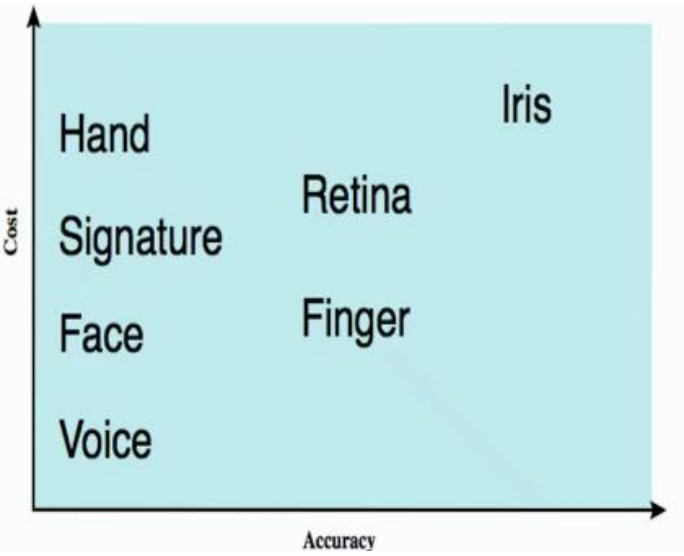
هي طريقة للتحقق من هوية المستخدم تعتمد على ما هو عليه المستخدم (Who the user is من خلال خصائص بيولوجية أو سلوكية فريدة يصعب تقليدها أو سرقتها.

أمثلة على الخصائص الفيزيائية (: Biometrics)

- بصمة الإصبع (Fingerprint)
- بصمة العين / قزحية العين (Iris Scan)
- التعرف على الوجه (Face Recognition)
- بصمة الصوت (Voice Recognition)

الفكرة الأساسية:

يتم مقارنة الخاصية الحيوية للمستخدم مع بيانات مخزنة مسبقًا للتأكد من هويته.



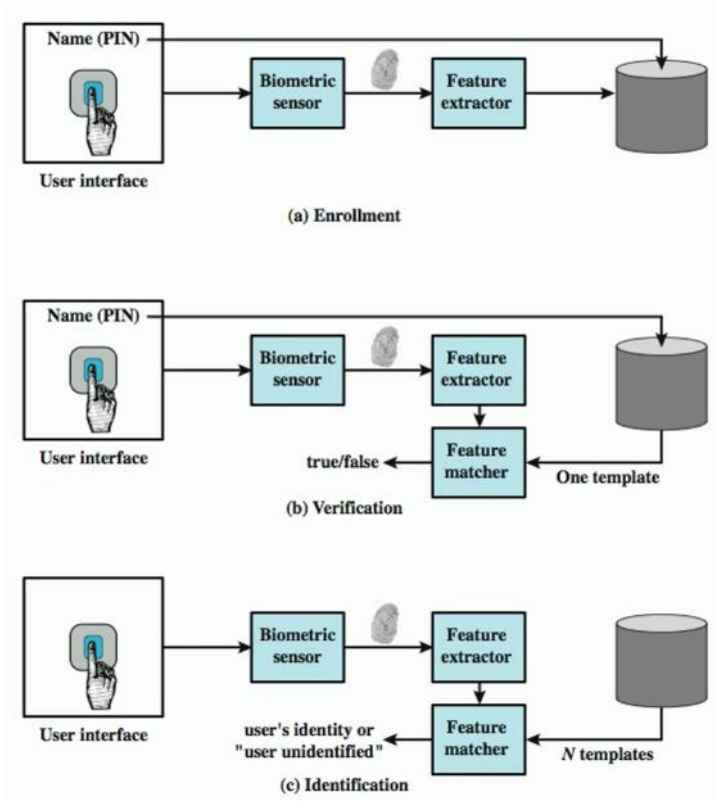
المميزات:

- صعب التزوير أو السرقة مقارنة بكلمات المرور أو البطاقات
- لا يحتاج المستخدم لتذكر كلمات مرور
- يوفر مستوى أمان مرتفع

العيوب:

- قد تكون الأجهزة مكلفة
- احتمالية حدوث أخطاء في التعرف (False Accept / False Reject)
- مخاوف تتعلق بالخصوصية لأن البيانات الحيوية لا يمكن تغييرها إذا تم تسريبها

Operation of a Biometric System



Operating the biometrics system

يوضح الشكل ٣,٧ في النص كيفية عمل نظام القياسات الحيوية (Biometric System) كما يلي:

يجب أولا تسجيل كل مستخدم سيتم إدخاله في قاعدة بيانات المستخدمين المصرح لهم، وتسمى هذه العملية التسجيل ((Enrollment، وهي تشبه تعيين كلمة مرور للمستخدم في هذا النظام، يقوم المستخدم بتقديم اسمه، وغالبًا كلمة مرور أو رقم سري ((PIN)، وفي نفس الوقت يقوم النظام بقياس خاصية بيومترية لهذا المستخدم مثل بصمة الإصبع (مثلاً بصمة الإصبع الأيمن للإصبع السبابة).

يقوم النظام بعد ذلك بتحويل هذه البيانات إلى صيغة رقمية ((Digitization ، ثم يستخرج مجموعة من الخصائص ((Featuresيتم تخزينها على شكل رقم أو مجموعة أرقام تمثل هذه الخاصية الفريدة. وتُسمى هذه المجموعة من القيم قالب المستخدم ((User Template وبهذا يصبح المستخدم مسجلا في النظام الذي يحتفظ باسمه ((ID وربما PIN أو كلمة مرور، بالإضافة إلى بياناته البيومترية.

اعتمادًا على التطبيق، فإن المصادقة في الأنظمة البيومترية تنقسم إلى نوعين: التحقق (Verification Identification)) والتحديد

في حالة التحقق ((Verification ، وهي تشبه تسجيل الدخول باستخدام بطاقة ذكية أو بطاقة ذاكرة مع كلمة مرور أو PIN، يقوم المستخدم بإدخال رقم سري واستخدام حساس بيومتري. يقوم النظام باستخراج الخاصية البيومترية ومقارنتها بالقالب المخزن لهذا المستخدم. إذا حدث تطابق، يتم قبول المستخدم.

أما في حالة التحديد ((Identification ، فيستخدم الشخص الحساس البيومتري فقط دون تقديم أي معلومات إضافية. يقوم النظام بمقارنة القالب المقدم مع جميع القوالب المخزنة في قاعدة البيانات. إذا وجد تطابقا، يتم تحديد هوية المستخدم، وإذا لم يوجد يتم رفضه.

Biometric accuracy

في أي نظام من أنظمة القياسات الحيوية (Biometric Systems ، يتم تحويل الخاصية الفيزيائية للفرد إلى تمثيل رقمي. ولكل فرد يتم تخزين تمثيل رقمي واحد يُسمى القالب) (Template داخل الحاسوب. وعند عملية التحقق من هوية المستخدم، يقوم النظام بمقارنة القالب المخزن مع القالب الذي يتم تقديمه أثناء الاستخدام.

وبسبب تعقيد الخصائص الفيزيائية للبشر، لا يمكن توقع وجود تطابق تام بين القالبين. لذلك يستخدم النظام خوارزمية تقوم بحساب درجة تطابق (Matching Score ، وهي غالبًا قيمة رقمية واحدة تعبر عن مدى التشابه بين القالبين.

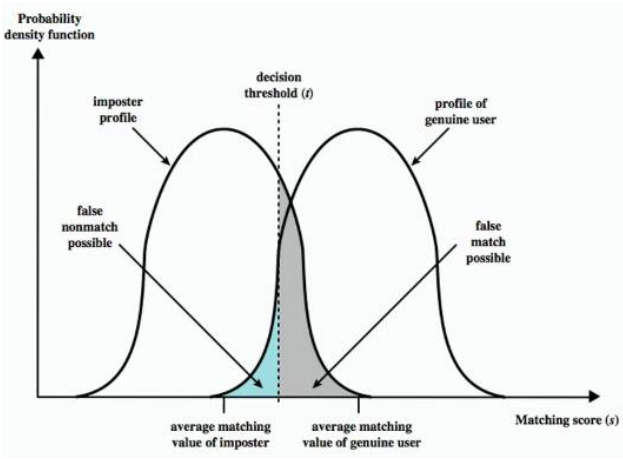
يوضح الشكل ٣,٨ المشكلة التي يواجهها النظام. فإذا تم اختبار نفس المستخدم عدة مرات، فإن درجات التطابق ستتغير في كل مرة، لكنها غالبًا تتبع توزيعا إحصائيًا على شكل منحنى جرسي (Bell Curve في المتوسط، فإن أي شخص آخر محتال أو غير مصرح له سيحصل

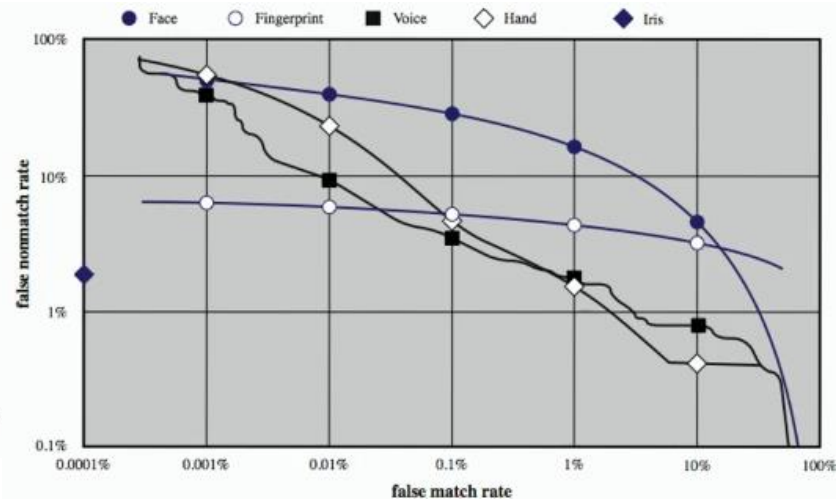
على درجات تطابق أقل بكثير، ولكن هذه القيم أيضًا تتبع توزيعا مشابها على شكل منحنى جرسي.

المشكلة الأساسية هي أن نطاق درجات التطابق بين المستخدم الحقيقي والمستخدم المزيف قد يتداخل في الشكل، يتم اختيار قيمة حدية (Threshold) بحيث إذا كانت درجة التطابق s t يتم قبول المطابقة، وإذا كانت s < t يتم رفضها.

المنطقة المظللة على يمين العتبة تمثل الحالات التي قد يحدث فيها قبول خاطئ False Match بينما المنطقة المظللة على يسار العتبة تمثل الحالات التي قد يحدث فيها رفض خاطئ (False Nonmatch. وتمثل مساحة كل منطقة احتمال حدوث هذا الخطأ.

ومن خلال تغيير قيمة العتبة (رفعها أو خفضها، يمكن تقليل أحد نوعي الأخطاء، ولكن ذلك يؤدي بالضرورة إلى زيادة النوع الآخر ، أي أن تقليل معدل القبول الخاطئ يؤدي إلى زيادة معدل الرفض الخاطئ والعكس صحيح.





يمكن تمثيل أداء أنظمة القياسات الحيوية بمنحنى يوضح العلاقة بين معدل القبول الخاطئ ومعدل الرفض الخاطئ. يتم اختيار عتبة (Threshold) لتحديد قبول أو رفض المستخدم، لكن هناك دائمًا مفاضلة: تقليل أحد النوعين من الأخطاء يؤدي إلى زيادة الآخر.

في الأنظمة عالية الأمان يتم تقليل القبول الخاطئ جدا، بينما في التطبيقات الجنائية يتم تقليل الرفض الخاطئ لضمان عدم فقدان أي مرشح محتمل.

أظهرت الاختبارات العملية أن نظام التعرف على القزحية يتميز بدقة عالية جدا (بدون أخطاء قبول تقريبًا)، بينما كان نظام التعرف على الوجه الأقل أداءً مقارنة بالأنظمة الأخرى.

practical application

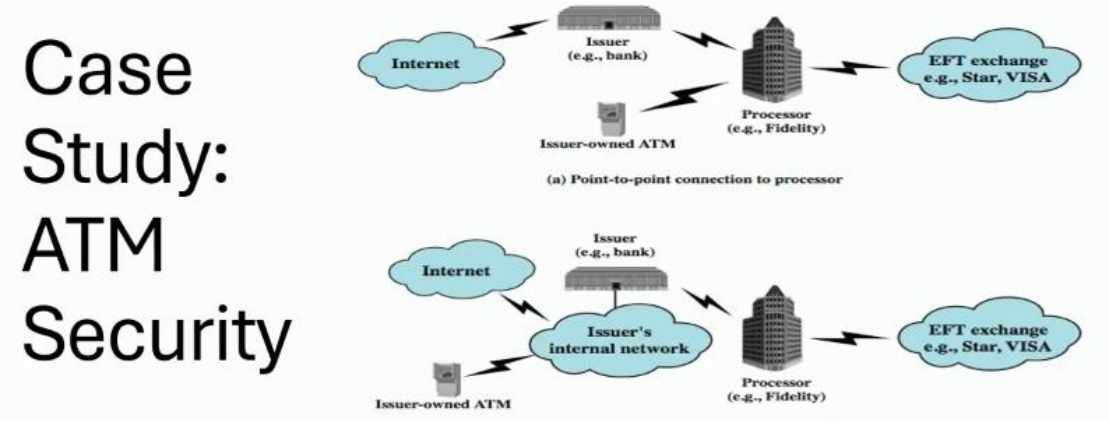
يصف النص نظامًا بيومتريًا يعتمد على التعرف على قزحية العين (Iris (Recognition ويُستخدم في القطاع البنكي للتحقق من هوية مستخدمي بطاقات الخصم عبر أجهزة الصراف الآلي ((ATMيتميز هذا النظام بدقة عالية جدًا وإمكانية استخدامه بدون تلامس مباشر مع الجهاز.

في أجهزة الصراف الآلي، تقوم كاميرا واسعة بتحديد وجه المستخدم ثم تكبير الصورة لالتقاط القزحية، وبعدها يتم تحويل الصورة إلى رمز رقمي ((Iris Code باستخدام نقاط وخصائص مميزة في القزحية.

يمكن أيضا استخدام أجهزة منزلية منخفضة التكلفة، لكنها تتطلب تعاونًا أكبر من المستخدم لالتقاط الصورة بدقة. يتم تسجيل المستخدم لأول مرة عبر جهاز ATM، حيث تُحوّل القزحية إلى رمز رقمي ويُربط مع رقم تعريف العميل ((CIN، ثم يتم تشفير البيانات وإرسالها إلى خادم البنك للتحقق.

في الاستخدام عبر الإنترنت، تُرسل بيانات القزحية مع رقم العميل بشكل آمن إلى خادم البنك الذي يقوم بعملية التحقق عبر الشبكة الداخلية.

أظهرت التجارب الميدانية أن المستخدمين يفضلون هذا النظام بشكل كبير مقارنة بطرق المصادقة التقليدية الأخرى.



ناقش النص ثغرة أمنية في استخدام أجهزة الصراف الآلي ((ATMلدى بعض البنوك الصغيرة والمتوسطة التي تعتمد على مزودي خدمات خارجيين لمعالجة عمليات السحب والتحويل الإلكتروني.

في النظام القديم، كانت أجهزة الصراف الآلي تتصل مباشرة بمعالج الخدمة عبر خطوط مخصصة ((Leased Lines مما يقلل خطر اعتراض البيانات.

لكن في أوائل ٢٠٠٠ ، بدأت البنوك في تحديث أنظمتها وربط أجهزة الصراف بشبكاتها الداخلية المتصلة بالإنترنت، مع إبقاء خط واحد فقط إلى مزود الخدمة، وذلك لتقليل التكاليف وتسهيل الإدارة.

هذا التغيير جعل بيانات المعاملات تمر عبر شبكة البنك الداخلية قبل وصولها إلى المعالج، مما خلق نقطة ضعف أمنية. إذ يمكن لمهاجم داخل الشبكة أو عبر الإنترنت اعتراض بيانات معاملات العملاء والوصول إليها.

وتكمن المشكلة الأساسية في ضعف السرية ((Confidentiality وسلامة البيانات (Integrity)، حيث يمكن التنصت على المعلومات أو تعديلها أثناء انتقالها داخل الشبكة.

summary

إدخال مصادقة المستخدم (User Authentication)

تم إدخال طرق متعددة للتحقق من هوية المستخدم بهدف تعزيز أمن الأنظمة، وتشمل:

- استخدام كلمات المرور (Passwords)
- استخدام الرموز أو التوكن (Tokens)
- استخدام القياسات الحيوية (Biometrics)

مشكلات المصادقة للمستخدمين عن بعد (Remote User Authentication)

- صعوبة التحقق من هوية المستخدم عبر الشبكات غير الآمنة
- إمكانية اعتراض بيانات المصادقة أثناء الإرسال
- الحاجة إلى حماية قوية للاتصالات بين المستخدم والنظام

تطبيقات وحالات دراسية Example Applications and Case Study

- أنظمة البنوك والصراف الآلي (ATM)
- الخدمات المصرفية عبر الإنترنت (Online Banking)
- الأنظمة المؤسسية التي تسمح بالوصول عن بعد (Remote Access Systems)

توضح هذه الحالات أهمية استخدام وسائل مصادقة متعددة ومتكاملة لضمان أمان الوصول عن بعد.

التطبيقات والحالات الدراسية (Example Applications and Case study):

- أنظمة الصراف البنوك وأجهزة الآلي : (ATM)

تستخدم المصادقة للتحقق من هوية المستخدم أثناء عمليات السحب والإيداع والتحويل، غالبًا باستخدام البطاقة + رقم سري (PIN) ، وقد تُضاف تقنيات أكثر تقدمًا مثل التشفير أو القياسات الحيوية.

- الخدمات المصرفية عبر الإنترنت : (Online Banking)

تعتمد على التحقق من هوية المستخدم عند الدخول إلى الحسابات البنكية عبر الإنترنت، باستخدام كلمات المرور، أو الرموز المؤقتة (OTP) ، أو المصادقة متعددة العوامل (MFA) لضمان الأمان.